

Phishing Analysis Research: Deconstruction of a Live Microsoft Credential Theft Campaign

Author: Ishaan Malhotra

Date of Analysis: September 25, 2025

Analysis Subject: sample-1011.eml

Classification: Confirmed Malicious Phishing Attempt

1. Introduction

1.1. Background

Phishing remains one of the most prevalent and effective cyber attack vectors. Attackers leverage social engineering and technical deception to impersonate trusted entities, aiming to trick victims into divulging sensitive information such as login credentials, financial details, or personal data. This project analyzes a real-world phishing email to deconstruct the techniques used by attackers.

1.2. Objective

The primary objective of this investigation was to perform a comprehensive analysis of the suspected phishing email (sample-1011.eml) to:

- Verify the authenticity of the sender.
- Identify technical indicators of forgery within the email headers.
- Analyze the social engineering tactics used in the email body.
- Safely investigate the payload link to determine its threat level.

1.3. Methodology

The analysis was conducted within an isolated Kali Linux virtual environment to ensure safety. The methodology involved a multi-stage process:

1. **Static Analysis:** The raw source of the .eml file was examined using a text editor to dissect its headers and HTML structure without rendering its content.
 2. **Safe Link Extraction:** The grep command-line utility was used to extract all hyperlinks from the source code for external analysis.
 3. **Threat Intelligence Analysis:** The extracted URL was submitted to VirusTotal, a public aggregate of security vendor scan results, to assess its reputation and identify known threats.
-

2. Detailed Analysis & Findings

2.1. Header Analysis: Proof of Forgery

The email headers provide a technical fingerprint of the message's journey and authenticity. To inspect the file safely, the raw source of the email was first opened using the less command in the terminal. This method allows for viewing the content without rendering any potentially malicious HTML or images.

The following command was used to view the file:

```
less sample-1011.eml
```

```
File Actions Edit View Help
Received: from PH7PR19MB5920.namprd19.prod.outlook.com (::1) by
MN0PR19MB6312.namprd19.prod.outlook.com with HTTPS; Thu, 27 Jul 2023 07:40:06
+0000
Received: from AM6P194CA0105.EURP194.PROD.OUTLOOK.COM (2603:10a6:209:8f::46)
by PH7PR19MB5920.namprd19.prod.outlook.com (2603:10b6:510:1db::17) with
Microsoft SMTP Server (version=TLS1_2,
cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6609.33; Thu, 27 Jul
2023 07:40:04 +0000
Received: from VI1EUR06FT066.eop-eur06.prod.protection.outlook.com
(2603:10a6:209:8f:cafe::93) by AM6P194CA0105.outlook.office365.com
(2603:10a6:209:8f::46) with Microsoft SMTP Server (version=TLS1_2,
cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6631.29 via Frontend
Transport; Thu, 27 Jul 2023 07:40:03 +0000
Authentication-Results: spf=none (sender IP is 89.144.9.87)
smtp.mailfrom=nonkfrgr.co.uk; dkim=none (message not signed)
header.d=none; dmarc=permerror action=none header.from=access-accsecurity.com;
Received-SPF: None (protection.outlook.com: nonkfrgr.co.uk does not designate
permitted sender hosts)
Received: from nonkfrgr.co.uk (89.144.9.87) by
VI1EUR06FT066.mail.protection.outlook.com (10.13.6.228) with Microsoft SMTP
Server id 15.20.6631.29 via Frontend Transport; Thu, 27 Jul 2023 07:40:03
+0000
X-IncomingTopHeaderMarker:
OriginalChecksum:581851118E8AB60FB557B9652148A1D2ACF0E25191DB3370DD6E91B6F7AF2E34;UpperCasedChecksum:650D4BED9803
From: Microsoft account team , <no-reply@access-accsecurity.com>
Subject: Microsoft account unusual signin activity
To: phishing@pot
Content-Length: 18708448
Content-Length: 1821750
Date: Thu, 27 Jul 2023 07:40:03 +0000
Reply-To: solutionteamrecognizd02@gmail.com
Content-Type: text/html; charset="UTF-8"
Content-Transfer-Encoding: 8bit
X-IncomingHeaderCount: 12
Message-ID:
<412928a2-0aad-4b27-959a-5df404e1f07d@VI1EUR06FT066.eop-eur06.prod.protection.outlook.com>
Return-Path: bounce@nonkfrgr.co.uk
X-MS-Exchange-Organization-ExpirationStartTime: 27 Jul 2023 07:40:03.4716
(UTC)
X-MS-Exchange-Organization-ExpirationStartTimeReason: OriginalSubmit
X-MS-Exchange-Organization-ExpirationInterval: 1:00:00:00.0000000
X-MS-Exchange-Organization-ExpirationIntervalReason: OriginalSubmit
X-MS-Exchange-Organization-Network-Message-Id:
92ccd2d7-4aa5-4320-c208-08db8e74b0af
X-EOPAttributedMessage: 0
X-EOPTenantAttributedMessage: 84df9e7f-e9f6-40af-b435-aaaaaaaaaaaa:0
X-MS-Exchange-Organization-MessageDirectionality: Incoming
X-MS-PublicTrafficType: Email
X-MS-TrafficTypeDiagnostic:
VI1EUR06FT066:EE_|PH7PR19MB5920:EE_|MN0PR19MB6312:EE_
```

Key findings from the headers (shown in this image) include:

- **Sender Impersonation:** The From: header displayed "Microsoft account team <no-reply@access-accsecurity.com>," a domain clearly not owned by Microsoft.
- **Authentication Failure:** The Authentication-Results header reported a complete failure of standard email verification protocols:
 - **spf=none:** Sender Policy Framework (SPF) could not be verified, as the sending domain (nonkfrgr.co.uk) had no published SPF record. This means there is no policy to prevent others from sending emails on its behalf.

- **dkim=none:** DomainKeys Identified Mail (DKIM) was not present. The email lacked a digital signature, meaning its integrity and origin could not be verified.
- **True Origin Identified:** The Received: header clearly shows the email originated from a server named **nonkfrgr.co.uk** at the IP address **89.144.9.87**. This contradicts the sender's claim of being Microsoft.

2.2. Content Analysis: Social Engineering Tactics

The email's content was crafted to exploit human psychology.

- **Subject Line:** "Microsoft account unusual signing activity"
- **Analysis:** This subject line is a classic social engineering tactic that creates a powerful sense of **fear** and **urgency**. It implies the victim's account is already compromised, pressuring them to bypass normal security caution and react immediately to the perceived threat.

2.3. Payload Link Analysis: The Active Threat

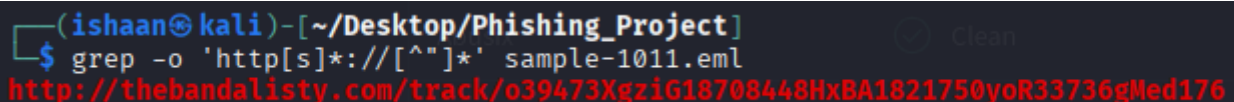
The ultimate goal of the email was to direct the user to a malicious website.

2.3.1. Safe Extraction of URL

The link was safely extracted using the following command to avoid accidental exposure.

Bash

```
grep -o 'http[s]*://[^"]*' sample-1011.eml
```



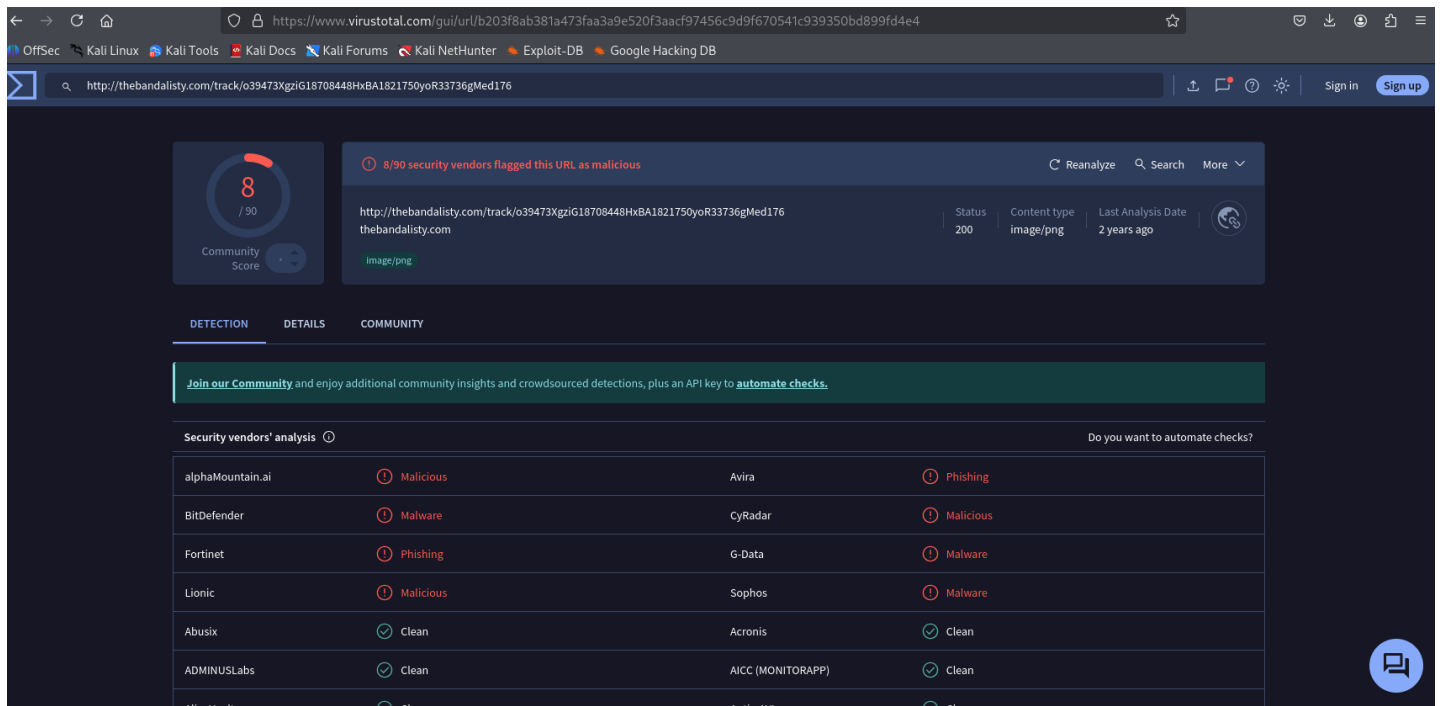
```
(ishaan@kali)-[~/Desktop/Phishing_Project]
$ grep -o 'http[s]*://[^"]*' sample-1011.eml
http://thebandalisty.com/track/o39473XgziG18708448HxBA1821750yoR33736gMed176
```

The screenshot shows a terminal window with the command `grep -o 'http[s]*://[^"]*' sample-1011.eml` executed. The output is the URL `http://thebandalisty.com/track/o39473XgziG18708448HxBA1821750yoR33736gMed176` displayed in red text. A 'Clean' button is visible in the top right corner of the terminal window.

The command extracted the primary payload link:
`http://thebandalisty.com/track/...`

2.3.2. Threat Verification

The extracted URL was submitted to VirusTotal for analysis. The scan confirmed the link is malicious.



As shown this image, the URL was flagged by **8 out of 90** security vendors. The detections explicitly classify the link as "**Malicious**," "**Phishing**," and "**Malware**." This confirms that the link leads to a known-bad website, likely a credential harvesting page designed to look like a real Microsoft login form.

3. Conclusion

The email sample-1011.eml is definitively a **dangerous phishing attack**. The campaign combines technical forgery (spoofed sender, failed authentication) with psychological manipulation (fear, urgency) to lure victims into clicking a malicious link. The link was confirmed by threat intelligence platforms to lead to a dangerous web property. The attack's primary goal is the theft of Microsoft account credentials, which could lead to identity theft, financial loss, and further compromises.

4. Mitigation & Recommendations

To defend against such threats, the following security best practices are recommended:

- **Verify Sender Identity:** Always carefully inspect the sender's email address, not just the display name.

- **Never Click, Navigate Directly:** In response to unexpected security alerts, never click the provided links. Instead, open a new browser window and manually type the official URL of the service (e.g., account.microsoft.com) to check your account status.
- **Enable Multi-Factor Authentication (MFA):** MFA is the single most effective control to prevent account takeover, as it requires a second form of verification that the attacker does not have.